Anti-Vibe Coding Standard

Continuous Repository Alignment for Proof-Carrying AI Pull Requests

Find the vibe. Prove the merge. Repair the repo.

Jankurai Project • github.com/jeppsontaylor/jankurai

Status `public_draft` **Standard** `0.7.0` **Auditor** `0.7.0`
Schema `1.5.0` **Paper edition** `2026.05-ed7`

Abstract

AI-assisted coding makes plausible code cheap and vibe-code drift expensive. Jankurai is a versioned repository conformance standard for finding and reducing *vibe artifacts*: ownerless paths, unmapped proof, hand-edited generated zones, stale contracts, false-green tests, missing security evidence, overbroad agent permissions, unproven UI changes, and unreceipted review claims. Its central artifact is the *merge witness*, a versioned binding among changed paths, owner routes, required proof receipts, observed evidence, score deltas, missing-evidence decisions, tool identity, artifact digests, and commit identity.

Jankurai treats the repository as the alignment layer for human- and agent-authored code. A local, pull-request, and CI loop maps each changed path to bounded authority, proof lanes, evidence receipts, repair queues, or expiring waivers. The result is not a larger prompt or a hosted trust service; it is a reproducible merge decision that can be audited at the current commit.

The paper contributes a stack-neutral repository model with owner maps, test maps, generated-zone policy, stable rule identifiers, version manifests, bounded authority, proof receipts, audit reports, repair queues, merge witnesses, and a seed conformance suite. The claim is bounded: Jankurai does not prove full program semantics, does not require a Rust/TypeScript/PostgreSQL stack, and does not treat scores as merge approval. It proposes a version-controlled standard for turning vibe coding into repairable evidence.

Index Terms—vibe coding, vibe artifacts, continuous repository alignment, proof-carrying pull requests, merge witness, repair queues, agent efficiency, repository governance, software evidence.

I. From Vibe Coding to Verified Merge

An agent opens a pull request that changes a checkout flow. The diff touches product UI, a generated API client, a schema-adjacent file, tests, and documentation. The hard reviewer question is no longer whether the patch looks plausible. It is: what evidence makes this safe to merge?

That question is the center of Jankurai. AI-assisted coding makes plausible code cheap; it makes ambiguous repositories expensive. GitHub's 2025 Octoverse report describes AI as mainstream in development and TypeScript as the most-used language on GitHub [1]. DORA's 2025 research frames AI as an amplifier of existing organizational capability rather than an automatic productivity guarantee [2]. Security evidence is less forgiving: Veracode reports syntactically plausible generated code with known flaws [3], and GitGuardian reports accelerating secret exposure in public GitHub activity, including AI-assisted commits [4], [5].

The correct response is not to slow agents down until the old review process survives. The correct response is to redesign the repository as the alignment layer. The repository, not the prompt or the reviewer memory, must encode ownership, allowed edit scope, proof lanes, generated boundaries, permission limits, evidence receipts, repair queues, and versioned conformance.

Jankurai's operating claims are deliberately concrete:

- The repository is the alignment layer for human- and agent-authored code.
- Vibe artifacts are detectable as repository states, not merely as reviewer discomfort.
- Vibe artifacts are reducible when findings route to owners, proof lanes, receipts, and repair queues.
- Reducing vibe artifacts improves agent efficiency by replacing broad context rereads and improvised proof selection with path-scoped policy and reusable evidence.

The checkout-flow pull request is the running example. If the generated client changed by hand, the repository should emit `HLT-002-GENERATED-MUTATION`. If the UI changed without screenshot, ARIA, trace, or geometry evidence, it should emit `HLT-013-RENDERED-UX-GAP`. If the path has no owner or proof route, it should emit `HLT-003-OWNERLESS-PATH` or `HLT-004-UNMAPPED-PROOF`. The merge witness then records whether the PR can pass, needs human review, must block, violates a ratchet, or fails release gates.

Agent-native engineering is not "humans approve whatever the model says." It is human-directed engineering in which intent becomes bounded authority, changed paths become proof lanes, proof lanes leave evidence, evidence drives repair or waiver expiry, and repeated repairs become reusable primitives. The same machinery must govern human-authored code, because a vague PR from a person and a vague patch from an agent fail in the same place: the repository cannot tell what owns the behavior, which proof applies, or what evidence would make the merge trustworthy.

This paper makes four contributions. First, it defines a stack-neutral repository conformance model for continuous repository alignment. Second, it specifies a merge-witness artifact that binds changed paths to ownership, proof, evidence, and decision. Third, it turns missing evidence into stable rule IDs and an ordered repair queue. Fourth, it reports current seed conformance-suite evidence and separates the non-normative reference profile from Jankurai Core.

II. Definitions and Threat Model

Vibe coding is any development mode where plausible code is accepted without explicit ownership, proof routing, generated-boundary checks, security gates, UX evidence, and repair evidence. Jankurai does not merely criticize vibe coding. It serializes vibe artifacts, assigns stable rule IDs, routes them to proof lanes, and reduces them through repair receipts.

The standard does not claim every repository using AI must adopt Jankurai. It claims a narrower and testable thing: a repository claiming Jankurai conformance must expose enough machine-readable structure for the claim to be audited. Conformance is a public interface, not a vibe.

change proposal → changed paths → vibe artifact scan → owner route → proof lane → receipt → merge witness → `pass`/`review`/`block`/`ratchet_fail`/`release_fail` → repair queue or waiver → reduced baseline

Fig. 1. The Jankurai continuous repository alignment loop. A change is not trusted because it looks plausible; it is trusted only when changed paths, owners, proof receipts, missing evidence, artifact digests, and commit/tool identity are bound into a merge witness.

TABLE I
CORE TERMS.

Term	Operational meaning
Vibe artifact	Repository residue that makes a change plausible but not auditable: ownerless paths, unmapped proof, hand-edited generated zones, stale contracts, false-green tests, missing security evidence, overbroad agent authority, unproven UI changes, stale waivers, or review claims without receipts.
Vibe-code drift	The measurable gap between claimed engineering intent and evidence attached to a change.
Continuous repository alignment	The practice of keeping ownership, edit scope, proof lanes, generated boundaries, permissions, evidence, repair queues, and conformance metadata synchronized with each merge.
Real-time repository conformance	A repeatable local/PR/CI loop in which each changed path is evaluated against current repository policy before merge; it is not a claim of an omniscient daemon.
Proof freshness	A receipt is current for the changed-path scope, commit, tool identity, command identity, and declared lane it claims to prove.
Receipt validity	A receipt is replayable or inspectable enough to bind command, cwd, inputs, tool version, result, artifacts, and digest to the current merge witness.
Policy authority	The ordered source of truth used to decide which instructions, maps, lanes, and adapter claims are trusted.
Adapter drift	Divergence between provider instruction files and canonical repository policy.
Evidence bundle	A versioned group of reports, receipts, logs, screenshots, ARIA snapshots, digests, and witness artifacts used to audit a claim.
Conformance claim	A machine-readable statement that a repository meets a named Jankurai level at a commit under a standard, auditor, and schema version.
Proof receipt	A durable record of a proof command, tool identity, inputs, result, and artifact path.
Merge witness	A versioned artifact binding changed paths, owner route, proof receipts, score delta, missing-evidence decision, artifact digests, commit identity, and tool version.
Generated zone	An output path repaired by changing the declared source contract or generator and regenerating, not by hand edit.
Repair queue	Ordered findings with rule IDs, owners, proof lanes, rerun commands, evidence requirements, and bounded next actions.
Reference profile	A non-normative stack or implementation profile that can satisfy the standard without defining it.

TABLE II
THREAT MODEL FOR AUDITABLE MERGE.

Threat	Risk	Jankurai control
False plausibility	Agent or human patch looks idiomatic but violates architecture, data, security, or runtime expectations.	Stable rule IDs, owner maps, proof lanes, generated-zone policy, and merge witness.
Fabricated, stale, or copied receipts	A proof claim names evidence that did not run for this commit, path scope, tool, or command.	Proof freshness checks, artifact digests, receipt validity rules, and witness binding.
Adapter drift	Tool-specific instruction files widen permissions or contradict canonical policy.	Source-of-authority hierarchy, adapter verification, policy digests, and generated mirrors.
Flaky proof lanes	Intermittent tests hide real failures or make proof receipts unreliable.	Lane contracts with timeout, environment, retry policy, artifact paths, and failure classification.
Emergency bypass	Urgent work merges without owner, security, release, or proof evidence.	Expiring waivers, compensating controls, release-fail decisions, and repair receipts.
Evidence leakage	Screenshots, logs, traces, prompts, or artifacts expose secrets or customer data.	Redaction policy, artifact allowlists, secret scans, retention bounds, and privacy receipts.
CI downgrade	A workflow disables proof, widens permissions, removes artifacts, or changes branch gates.	CI hardening rule, workflow diff checks, pinned actions, and required evidence uploads.
Malicious MCP or tool schema	External tool output or schema attempts to change trusted policy or execute unsafe commands.	Untrusted-content isolation, schema validation, permission receipts, and no direct execution of generated text.
Generated test self-confirmation	Generated code and generated tests confirm the same wrong assumption.	Owner-owned acceptance criteria, negative fixtures, semantic assertions, and changed-path routing.
Human rubber-stamp review	Review approval lacks reproducible evidence or merely endorses plausible code.	Human-review evidence rule, receipt requirement, and merge witness decision record.
Screenshots or logs leaking secrets	Browser and observability evidence captures tokens, PII, prompt text, or private data.	UX/security evidence redaction, hash-based references, and artifact privacy status.
Out of scope	Full semantic correctness, malicious compiler/runtime integrity, and organizational governance outside the repository.	Explicit limitations, signed-receipt future work, and no claim of total program proof.

III. Jankurai Core Standard and Conformance

Jankurai Core is the standard interface. It is not a claim that all repositories should use one language, database, CI provider, or coding agent. It binds prose, machine-readable maps, generated-zone policy, audit output, proof receipts, repair evidence, CI behavior, and release governance into repository-local conformance claims.

The standard's public primitive is the merge witness:

$$\begin{aligned}\text{merge witness} = {} & \text{changed paths} + \text{owner route} \\ & + \text{required proof receipts} + \text{score delta} \\ & + \text{missing evidence decision} + \text{artifact digests} \\ & + \text{commit/tool identity}\end{aligned}$$

```
{
  "schema": "jankurai.merge_witness.v1",
  "standard_version": "0.7.0",
  "auditor_version": "0.7.0",
  "schema_version": "1.5.0",
  "current_commit": "9f3a1c4",
  "tool_version": "jankurai 0.7.0",
  "changed_paths": [
    "apps/web/src/checkout/Checkout.tsx",
    "apps/web/src/generated/client.ts",
    "contracts/openapi/api.yaml"
  ],
  "owner_route": ["web", "contracts"],
  "required_receipts": ["web", "contract", "security"],
  "present_receipts": ["contract"],
  "missing_evidence": ["rendered_ux_receipt"],
  "artifact_digests": {
    "contract_receipt": "sha256:...",
    "audit_report": "sha256:..."
  },
  "score_delta": { "from": 91, "to": 89 },
  "decision": "block",
  "witness_path": "target/jankurai/merge-witness.json"
}
```

```
{
  "standard_version": "0.7.0",
  "auditor_version": "0.7.0",
  "schema_version": "1.5.0",
  "claimed_level": "HL3",
  "current_commit": "9f3a1c4",
  "decision": "block",
  "required_receipts": ["web", "contract", "security"],
  "missing_evidence": ["rendered_ux_receipt"],
  "witness_path": "target/jankurai/merge-witness.json"
}
```

The machine field is `schema_version`. A schema bundle is prose for the collection of report, witness, receipt, and evidence schemas identified by that version. Emitted audit, report, and profile claims use `target_stack_id`. The current manifest still carries `target_stack` as the repository's profile label; this edition treats that as manifest provenance, not a core conformance field. Likewise, `paper_edition` is provenance for this document and companion artifacts, not a required core field for every external conformance claim.

Conformance and score are deliberately separate. Conformance is pass/fail against required artifacts for the claimed level. Score is posture and prioritization. A high score without current required receipts is not conformant. A low score can still be useful as an advisory finding, but it MUST NOT be represented as merge approval.

The decision enum is closed in this edition: `pass`, `review`, `block`, `ratchet_fail`, and `release_fail`. Implementations may attach reasons, but they MUST NOT invent alternate merge states for core conformance reports.

A repository claiming HL3 or higher MUST provide a root agent router, `agent/standard-version.toml`, `agent/owner-map.json`, `agent/test-map.json`, `agent/generated-zones.toml`, one-command fast lane, audit JSON, audit Markdown, current proof receipts, a merge witness, and an ordered `agent_fix_queue`. It MUST bind `standard_version`, `auditor_version`, `schema_version`, and commit identity in emitted reports. It MUST NOT hand-edit generated zones, hide durable truth in the wrong layer, or merge high-risk changes without a mapped proof lane.

Receipt invalidation is part of conformance. A proof receipt is invalid when it names the wrong commit, omits command or tool identity, lacks artifact digest, uses stale changed-path scope, runs an undeclared proof command, uses local-only evidence for a release claim, omits required security/UX/DB evidence, or is not bound into the merge witness.

Jankurai borrows standards mechanics without claiming institutional equivalence. Normative requirements use BCP 14-style MUST, SHOULD, and MAY language for clarity [6]. Standard, auditor, schema, and paper artifacts use SemVer-like compatibility signaling where breaking report changes require a major version, additive fields are minor-compatible, and copy or clarification changes can remain patch compatible [7]. Current and previous releases follow the SPDX pattern of visible specification history [8]. The OpenAPI distinction between specification text and schema artifacts informs Jankurai's split between normative prose, JSON schemas, and patch/minor report compatibility [9]. W3C-style maturity

TABLE III
NORMATIVE ARTIFACT CHECKLIST BY CONFORMANCE LEVEL.

Artifact or behavior	HL1	HL2	HL3	HL4	HL5	Requirement
Versioned policy files and stable rule IDs	MUST	MUST	MUST	MUST	MUST	The repository exposes a versioned standard target and machine-readable rule families.
Changed-path inventory, owner routing, generated-zone detection	SHOULD	MUST	MUST	MUST	MUST	Merge decisions bind concrete paths to owners and generated boundaries.
Audit JSON and audit Markdown	MUST	MUST	MUST	MUST	MUST	Machines consume JSON; reviewers consume Markdown.
Required proof receipts and merge witness	MAY	SHOULD	MUST	MUST	MUST	HL3 requires a merge witness and current proof receipts for all required changed-path lanes.
Repair queue, score delta, historical audit comparison	MAY	SHOULD	SHOULD	MUST	MUST	The repo can route missing evidence and detect posture regression.
Reproducible conformance-suite pass	MAY	MAY	SHOULD	SHOULD	MUST	HL5 requires runnable fixtures and independently repeatable expected output.
Signed or independently verifiable receipts	MAY	MAY	MAY	SHOULD	SHOULD	Strongly recommended for release and federation; not required at HL3 in v0.7.0.

TABLE IV
JANKURAI CONFORMANCE LEVELS.

Level	Meaning
HL0	Unscored or unrouted.
HL1	Advisory: audit runs and emits JSON/Markdown, but findings do not block merge.
HL2	Guarded: critical caps, generated-zone mutation, and missing fast lane block merge.
HL3	Standard: high and critical findings block merge; current proof receipts and a merge witness are required for changed-path lanes.
HL4	Ratchet: score or finding posture cannot regress without a waiver and repair queue.
HL5	Release contract: audit, security, contracts, DB, e2e, versions, and release evidence gate shipped artifacts.

states make draft, candidate, implementation evidence, stable, superseded, and obsolete status explicit [10]. Kubernetes-style conformance means certification must rest on runnable tests and reproducible evidence, not branding [11]. OpenSSF Scorecard motivates automated open-source posture scoring as an adoption surface rather than a private checklist [12].

Stable rule identifiers make the standard repairable. `HLT-001` through `HLT-027` are stable rule families tied to evidence and repair, not just detector names. Appendix A expands these IDs into required evidence and repair fields.

Centerline drift is the score delta between a repository's claimed standard and its observed behavior. Hard caps are versioned policy, not final empirical truth. Alternate stacks can conform if they provide equivalent owner routing, generated boundaries, proof lanes, security evidence, UX evidence, repair artifacts, and merge witnesses; Rust, TypeScript, and PostgreSQL are profile choices, not Core requirements.

TABLE V
CURRENT JANKURAI CONTROL-PLANE SURFACES.

Surface	Commands	Control-plane role
Adoption and drift	`adopt`, `init`, `update`, `doctor`	Introduce the control plane without surprise writes, keep adapters and manifests current, and report stale or malformed evidence.
Context and adapters	`context-pack`, `adapters verify/sync`, `agent verify`, `hooks install`	Turn prompt files and IDE rules into bounded authority tied to owner maps, test maps, generated zones, hooks, and CI entrypoints.
Proof ledger	`lane`, `proof`, `prove`, `proof-verify`	Route changed paths, execute allowed proof commands, write receipts and evidence indexes, and verify proof artifacts against the current repo state.
Audit, witness, and score ledger	`audit`, `witness`, `score diff/trend`, `rules verify`, `issues export`	Emit JSON/Markdown/SARIF/JUnit/summary evidence, merge witnesses, rolling score diffs, ordered repair queues, and machine-readable issue rows.
Security and UX	`security run`, `ux ...`	Normalize secret, dependency, SBOM, workflow, and rendered-UX evidence under policy-controlled artifacts.
Repair and expiry	`repair-plan`, `repair`, `optimize`, `exceptions expire`	Convert findings into bounded repair plans, dry-run or gated apply receipts, optimization proposals, and expiring waivers.
Cells and public evidence	`registry`, `cell`, `bench`, `certify`, `govern`, `publish`	Promote repeated fixes into reusable cells and publish benchmark, certification, governance, badge, and evidence-bundle artifacts.

IV. VIBE-ARTIFACT TAXONOMY AND STABLE RULE IDS

Vibe coding is not a mood. It is a fault class: shipping code whose correctness depends on plausibility, confidence, or reviewer intuition instead of machine-checkable proof. A vibe artifact is the repository residue left behind by that workflow. The risk-priority number below is **RPN = impact $\times$ likelihood $\times$ detection difficulty**, with each factor scored 1–5. It is a Jankurai policy weight, not a universal incident statistic. Future releases should calibrate it against repair success, escaped defects, security regressions, and review time.

Public evidence supports treating vibe coding as a high-risk production pattern rather than a harmless workflow style. Veracode reports that AI-generated samples introduced risky security flaws in 45% of tests [3]. GitGuardian reports accelerating hardcoded-secret exposure in public GitHub activity and AI-service leak growth [4], [5]. Stack Overflow's 2025 survey reports that developers' largest AI frustration is output that is almost right but not quite, with time-consuming AI-code debugging close behind [13]. OWASP's LLM Top 10 names prompt injection, sensitive information disclosure, supply-chain risk, improper output handling, and excessive agency as first-order AI application risks [14]. SetupBench and ContextBench add the operational failure modes: agents still struggle with environment bootstrap and useful context retrieval [15], [16].

The v0.7.0 coverage method is mechanical: parse source rows, normalize issue families, map each row to one HLT rule, assign TLR/RPN, mark detector maturity, and emit registry/report artifacts. Every parsed row from `tips/vibe_coding/tip1.txt` through `tip5.txt` maps to exactly one canonical issue in `agent/vibe-coverage.toml`. Appendix A renders the generated summary: green means detector-backed Jankurai control plus proof/report evidence, yellow means a reviewed control family exists but still needs issue-specific fixture, CI, or governance evidence. The v0.7.0 registry has 0 unmapped rows.

Highest-priority controls. A Jankurai-conformant repo should block merges when a changed path has no proof lane, a public boundary has handwritten contract mirrors, durable truth moves outside the declared durable-truth owner, database constraint layer, or approved domain/application boundary, security or secret scans are absent for risky changes, agent permissions are broader than the lane requires, user-facing UI lacks rendered proof, or `fallback`/`TODO`/`stub` ships without a scoped waiver.

Known solutions are stronger for some rows than others. Secret scanning, SCA, contract generation, DB constraints, Playwright screenshots, axe checks, and generated-zone manifests are known controls. Model/prompt drift, AI visual triage, context retrieval failure, and human-label learning are still emerging controls; Jankurai treats them as soft findings until teams can attach deterministic evidence. The taxonomy turns insult into audit surface. A finding is useful only when it names the rule, points at exact evidence, gives a bounded repair, and can be serialized into an agent queue.

TLR bucket	RPN share	Relative weight
Security	32%	
Business truth	20%	
Contracts/data	13%	
Verification	13%	
Entropy	10%	
Context/setup	9%	
Repair	3%	

Fig. 2. TLR means Top-Level Risk. Shares are computed directly from Table VI: each row contributes its RPN to one TLR bucket, then bucket totals are rounded to whole percentages. The chart is a policy-priority model for Jankurai 0.7.0, not an incident-frequency measurement.

TABLE VI
RANKED VIBE-ARTIFACT TAXONOMY. RPN IS A JANKURAI POLICY PRIORITY, NOT AN EMPIRICAL FREQUENCY CLAIM.

TLR	RPN	Fault	Rule/lane	Required control	Detector maturity
Business truth	125	False-green business logic	HLT-008 / fast	Domain invariants, property tests, golden workflows, DB constraints, incident replay tests.	evidence-routed
Business truth	100	Authorization or data-isolation drift	HLT-022 / db	Role matrix tests, negative authz tests, owner-map routing, RLS where useful.	evidence-routed
Business truth	80	Idempotency or side-effect duplication	HLT-008 / release	Idempotency keys, replay tests, outbox/workflow proofs, double-charge negative cases.	evidence-routed
Security	80	Plausible insecure generated code	HLT-009 / security	SAST/SCA, secure-code rules, threat-model checklist, negative tests.	heuristic
Security	80	Secrets and identity sprawl	HLT-010 / security	Push protection, local/CI secret scans, redacted logs, credential inventory, transcript/artifact scan.	deterministic
Security	75	Customer-data or PII leakage	HLT-010 / security	Data classification, prompt/transcript redaction, retention policy, vector-store review, privacy tests.	governance-backed
Security	75	Excessive agent agency	HLT-012 / security	Least-privilege profiles, destructive-command gates, workspace-only writes, permission receipts.	heuristic
Security	75	Prompt injection and hostile context	HLT-011 / security	Source-trust hierarchy, untrusted-content isolation, tool-call validation, no secrets in context.	heuristic
Security	60	Improper AI/tool output handling	HLT-011 / security	Schema validation, output encoding, command sandboxing, no direct execution of generated text.	evidence-routed
Security	45	Dependency and supply-chain drift	HLT-016 / security	Dependency rationale, lockfile diff review, OSV/SCA, SBOM, provenance checks.	evidence-routed
Verification	64	False-green tests	HLT-008 / fast	Reviewer-owned acceptance criteria, mutation/fault checks, semantic assertions, red/green evidence.	evidence-routed
Context/setup	64	Context retrieval failure	HLT-015 / fast	Short root router, owner/test maps, local rules, symbol search, command-output filtering.	research
Contracts/data	60	Contract and DTO drift	HLT-007 / contract	Generated clients only, contract drift lane, generated-zone lock, compatibility tests.	heuristic
Contracts/data	60	Wrong-layer persistence	HLT-006 / db	DB access policy, adapters-only SQL, migration and constraint tests, forbidden imports.	heuristic
Contracts/data	60	Destructive migration or data-loss hazard	HLT-021 / db	Rollback/down plan, staged backfill, lock timeout, constraint proof, production rehearsal.	deterministic
Context/setup	48	Environment/setup hallucination	HLT-015 / fast	One-command setup, pinned toolchain, devcontainer where useful, setup proof lane.	evidence-routed
Verification	48	Pixel/UI regression	HLT-013 / web	Storybook states, Playwright screenshots, geometry rules, baseline governance, trace artifacts.	evidence-routed
Verification	48	Accessibility regression	HLT-014 / web	axe/ARIA checks, keyboard journeys, focus/target geometry, expert review for semantic gaps.	evidence-routed
Verification	48	Model, prompt, or eval drift	HLT-008 / ai-eval	Versioned prompts/models, eval baselines, golden datasets, provider-change receipts.	research
Repair	45	Observability and repair opacity	HLT-017 / observability	Problem details, stable error codes, OpenTelemetry attributes, correlation IDs, repair hints.	evidence-routed
Entropy	45	Dead-language normalization	HLT-001 / fast	Banned marker scan, scoped allowlist, owner, expiry, waiver record.	deterministic
Entropy	40	Orphan or dead reachable code	HLT-001 / fast	Reachability checks, owner review, deletion receipts, tests proving replacement path.	research
Entropy	36	Performance, memory, or concurrency regression	HLT-018 / release	Benchmarks, query-plan checks, load smoke tests, allocation budgets, tracing.	evidence-routed
Entropy	36	Mega-file or mega-function sprawl	HLT-008 / fast	LOC/function caps, split by owner/use case, focused tests before behavior edits.	heuristic
Contracts/data	30	Generated-zone mutation	HLT-002 / contract	Generated-zone manifest, source contract change, regeneration command, drift check.	deterministic
Context/setup	30	Documentation or instruction drift	HLT-015 / audit	Canonical manifest, generated mirrors, instruction lint, short root guidance.	heuristic

V. Evaluation and Conformance Evidence

Jankurai is currently best understood as a standards proposal with an early reference implementation, not as a completed empirical benchmark. The evaluation claim in this edition is conformance-oriented: can a repository emit reproducible artifacts that make the merge decision auditable?

A. Current Implementation Evidence

The `jankurai` CLI audits this repository and emits JSON and Markdown reports. It validates rule coverage from `agent/vibe-coverage.toml`, tracks generated zones, owner routes, proof lanes, score history, and repair queues where those controls are implemented, and builds this paper from source. The paper, schemas, agent maps, generated-zone manifest, audit reports, and generated coverage outputs are repository-local artifacts rather than hosted service state.

Current evidence remains limited. Some detectors are deterministic, such as secret-like content, generated-zone mutation, direct DB markers, destructive SQL heuristics, and dead-language markers. Other rows are policy-backed or advisory because they require project-specific fixtures, organizational proof, or semantic tests that cannot be inferred from repository shape alone.

B. Seed Conformance Suite

This edition includes a seed conformance suite under `conformance/`. It is not a benchmark and does not claim detector completeness. Its purpose is narrower: keep the standard's rule IDs, expected decisions, and merge-witness outcomes concrete enough for the reference auditor to validate and for future implementations to copy. Kubernetes conformance is a useful precedent because certification rests on repeatable tests and submitted evidence rather than branding alone [11].

The current seed suite contains 10 fixture directories and 12 expected JSON files. The `hl3-pass-minimal` fixture expects `pass`. The nine fail fixtures expect `block`. Primary rule examples are `HLT-002`, `HLT-003`, `HLT-004`, `HLT-010`, `HLT-012`, `HLT-013`, `HLT-021`, `HLT-022`, and `HLT-023`. The validation command is `rtk just conformance`.

TABLE VII
Seed conformance-suite fixtures in this repository.

Fixture class	Expected signal
HL3 pass	Known-good HL3 shape; expected audit and witness decision: `pass`.
Generated drift	`HLT-002` blocks generated output changed without source proof.
Ownerless path	`HLT-003` blocks an unmapped changed path.
Unmapped proof	`HLT-004` blocks a path without a proof route.
Secret sprawl	`HLT-010` blocks secret-like fixture content.
Overbroad agency	`HLT-012` blocks tool or agent authority broader than the lane.
Rendered UX gap	`HLT-013` requires screenshot, trace, geometry, or accessibility evidence for changed UI.
Destructive migration	`HLT-021` blocks destructive SQL without rollback, backfill, lock, and DB proof evidence.
Authz isolation	`HLT-022` requires owner/non-owner negative proof.
Input boundary	`HLT-023` requires deterministic negative proof for unsafe rendering or input boundaries.

Miniature walkthrough. In `generated-zone-mutation-fail`, the bad state is a generated output changed without its declared source contract and regeneration command. The expected finding is `HLT-002-GENERATED-MUTATION`. The required proof is a contract lane receipt showing the source contract changed and the generator reran, with artifact digests for the generated output. Until that receipt exists, the merge witness decision is `block`. The repair queue item should name the generated path, source path, regeneration command, owner route, and expected proof lane.

C. Research Metrics

The next empirical step is to measure whether the standard improves merge outcomes. Useful metrics include missing-evidence detection, false positives and false negatives, owner-route accuracy, proof-selection accuracy, review time, time-to-repair, CI runtime, regression prevention, security posture change, and token/context reduction. SetupBench and ContextBench show why environment bootstrap and context retrieval deserve direct measurement in agent workflows [15], [16]; Jankurai adds merge-evidence quality as the repository-local outcome to measure.

TABLE VIII
METRICS FOR MEASURING VIBE-ARTIFACT REDUCTION AND AGENT EFFICIENCY.

Metric	Meaning
Vibe artifact density	Open HLT findings per changed path, pull request, KLOC, or module.
Proof coverage ratio	Required proof lanes with current valid receipts divided by required lanes.
Owner route coverage	Changed paths matched to owner cells divided by all changed paths.
Generated-zone drift count	Hand-edited or stale generated outputs.
Repair half-life	Median time from finding to accepted repair receipt.
Context efficiency	Useful proof or retrieval success per context-pack token budget.
Witness completeness	Required witness fields present, current, and digest-bound.
Alignment drift	Delta from accepted conformance baseline.
Proof-selection accuracy	Required proof lanes selected without overbroad or missing lanes.

VI. AGENT REPOSITORY CONTROLS AND TOOL ADAPTERS

Public agent tooling converges on one lesson: instructions matter, but deterministic control surfaces matter more. Codex supports project guidance through `AGENTS.md` [17]. The community `AGENTS.md` specification frames the file as a plain Markdown companion for coding agents [18]. Claude Code loads project memory through `CLAUDE.md` and related hierarchy [19]. Cursor uses project rules with scope metadata [20]. GitHub Copilot supports repository and path-specific custom instructions [21]. These mechanisms should not become divergent manuals. They should be generated or mirrored from one canonical standard.

The adapter problem is an authority problem, not a formatting problem. Jankurai treats prompt files as thin routers over machine-readable policy: `agent/owner-map.json` says who may own a path, `agent/test-map.json` says which lane proves it, `agent/generated-zones.toml` says which outputs are read-only unless regenerated from source, and `agent/standard-version.toml` binds the instruction surface to the standard and paper edition.

The source-of-authority hierarchy is:

```
standard/version manifest -> owner/test/generated/security maps -> proof lanes -> adapter mirrors -> task prompt -> untrusted issue/PR/web/tool text
```

For example, if `AGENTS.md` appears to permit generated edits but `agent/generated-zones.toml` denies hand edits, adapter verification fails and the generated-zone policy wins. Provider files may summarize policy, but they may not widen permissions.

Token minimization is not a prompting trick; it is repository design. Large root instructions, duplicate architecture documents, stale docs, broad rereads, and noisy command output waste context and invite contradiction. ContextBench and SWE-Effi support this direction by treating useful context and resource constraints as first-class bottlenecks [16], [22]. Context-pack metrics should include token count, stale docs excluded, proof-selection precision, route confidence, false-exclusion rate, and first-pass repair success.

The context-pack contract is budgeted and trust-labeled. A pack carries `-max-tokens`, an estimated token count, included and excluded file lists, source-trust labels, changed paths, selected owner routes, selected proof lanes, and evidence pointers. The result is not a larger prompt. It is a smaller grant of authority backed by files the repo can audit.

VII. CONTINUOUS PROOF: FROM CHANGED PATHS TO MERGE WITNESS

Agent-native testing should be organized by proof question, not author convenience. Domain invariants need unit and property tests. Application workflows need authorization, idempotency, and transaction tests. Adapters need integration and contract tests. Durable data stores need migration, constraint, and schema drift checks. The browser needs component tests, rendered UX proof, and Playwright coverage for critical paths. Public benchmarks and open-source agents show that setup reliability, context retrieval, and interface design are central bottlenecks for autonomous repair [15], [16], [23]–[26].

The explosion of tests is useful only if routed. A repo with thousands of tests and no `test-map.json` still asks agents to guess. The standard therefore requires a fast lane for changed files, a contract lane for generated interfaces, a security lane for dependency and secret risk, a DB lane for migrations, a web lane for component and rendered UX proof, an e2e lane for critical browser behavior, and a release lane for full confidence.

```
[[lane]]
name = "web"
command = "just ux-qa"
cwd = "."
timeout_seconds = 120
network = "loopback_only"
write_paths = ["target/jankurai/ux/"]
artifacts = [
  "target/jankurai/ux/evidence.json",
  "target/jankurai/ux/screenshots/"
]
```

CI modes should be explicit. *Advisory* mode emits reports but does not fail merge. *Guarded* mode blocks critical caps. *Standard* mode enforces high and critical findings plus required receipts. *Ratchet* mode prevents score or finding regression without a named waiver. *Release* mode gates shipped artifacts on audit, contracts, security, DB, e2e, versions, and release evidence.

The continuous proof loop is concrete and local. A changed path enters `agent/owner-map.json` for

TABLE IX
AGENT ADAPTER CONFORMANCE CHECKLIST.

Check	Required evidence
Root router points to canonical policy	`AGENTS.md` or equivalent names the standard brief, maps, generated zones, and validation lanes.
Provider files do not widen permissions	Claude, Cursor, Copilot, Codex, hooks, and MCP guidance agree with owner/test/security/generated maps.
Context packs label trust	Included material is labeled as trusted policy, repo code, generated artifact, proof evidence, docs, or untrusted input.
Adapters bind to policy digest/version	Mirrors include or can verify standard version, schema version, and policy digest.
Conflicts fail closed	Contradictions select the narrower authority and produce an adapter drift finding.

TABLE X
AGENT TOOL ADAPTER MATRIX.

Tool family	Native surface	Jankurai adapter	Non-negotiable rule
Codex	`AGENTS.md`, local scoped instructions.	Root router plus local ownership files and mapped proof commands.	Do not duplicate durable policy outside the standard.
Claude Code	`CLAUDE.md`, project memory, local rules.	Mirror root router, version, commands, and generated zones.	Memory may summarize policy but not grant broader permissions.
Cursor	`.cursor/rules` with scope metadata.	Generate scoped rules from owner map and test map.	Glob rules must agree with owner-map paths.
GitHub Copilot	Repository and path-specific custom instructions.	Short repo-wide mirror plus path instructions for high-risk owners.	No private architecture fork in IDE guidance.
MCP and hooks	Tool schemas, hooks, and local automation.	Pin source, scope permissions, and separate untrusted data from trusted policy.	Tool output cannot rewrite authority.
Terminal agents	CLI prompt files, repo maps, shell wrappers.	Root router, filtered command output, raw-output escape hatch.	Tool convenience must not bypass CI gates.

TABLE XI
MINIMUM PROOF LANES BY OWNERSHIP CELL.

Layer	Minimum proof
Domain	Unit tests plus property tests for invariants and state machines.
Application	Integration tests for authz, idempotency, transactions, workflows.
Adapters	DB/external integration tests and failure injection.
Contracts	Generation check, drift check, compatibility check.
Durable data	Migration apply, constraint tests, RLS or tenant-policy tests where used.
Web	Typecheck, component tests, rendered UX QA, Playwright critical paths.
AI/data service	Contract tests, eval suites, no direct product-truth ownership.
Ops/security	Secret scan, dependency scan, provenance, audit gate.

ownership and `agent/test-map.json` for lane routing. `jankurai lane` or `jankurai proof` turns that route into a proof plan. `jankurai prove` executes allowed commands, writes command receipts and `target/jankurai/evidence-index.json`, and records artifact digests. `jankurai proof-verify` checks the plan and evidence against the current repository state. `jankurai audit` folds ownership, generated zones, proof receipts, security evidence, UX evidence, and score history into JSON/Markdown/SARIF/JUnit reports. `jankurai witness` compares the candidate against an accepted baseline and emits the PR proof matrix. Findings become a repair queue through `agent_fix_queue`, `issues export`, or `repair-plan`. This is the real-time part of Jankurai: not an omniscient daemon, but a repeatable local/PR/CI loop that makes merge evidence current.

```
jankurai witness . \
  --changed-from origin/main \
  --baseline agent/repo-score.json \
  --out target/jankurai/merge-witness.json \
  --md target/jankurai/merge-witness.md
```

The report itself is proof material. JSON and Markdown are the agent repair surface; SARIF, JUnit, GitHub step summaries, JSONL repair queues, and issue exports are integration surfaces. A failed score with no findings is invalid output: every below-floor dimension must produce at least one routed finding with owner, lane, rerun command, evidence kind, fingerprint, and queue item.

VIII. RENDERED UX AND BROWSER-STEP QA

The browser is a real runtime, not a screenshot afterthought. Agents can create UI that compiles, passes component tests, and still fails through overlapping text, broken responsive layout, invisible controls, stale selectors, missing focus states,

blank canvases, cramped buttons, clipped labels, sticky footer collisions, or layout shift. Playwright's official guidance emphasizes user-visible behavior, resilient locators, isolation, and web-first assertions, which fit agent repair better than brittle sleeps and CSS selectors [27], [28].

Rendered UX proof should be a contract, not a taste debate. The standard treats rendered UX as a layered proof system: design-system constraints, generated contracts, deterministic Storybook states, Playwright screenshots, DOM geometry rules, accessibility rules, visual regression, AI/CV triage, and human feedback labels. `@jankurai/ux-qa` is a reference implementation of the UX evidence contract, not the only conformant implementation.

```
{
  "route": "/checkout",
  "viewport": "390x844",
  "browser": "chromium-123",
  "screenshot_hash": "sha256:...",
  "aria_snapshot_hash": "sha256:...",
  "rule_ids": ["HLT-013", "UX-OVERLAP"],
  "selector": "[data-testid=submit-order]",
  "severity": "high",
  "decision": "block"
}
```

Some criteria are deterministic enough to be Jankurai evidence: overlap, clipping, horizontal overflow, target-size failures, missing focus visibility, severe CLS, blank critical surface, missing protected-route screenshot, clipped required text, sticky obstruction, and unapproved token violations. WCAG 2.2 target-size guidance defines a 24 by 24 CSS-pixel minimum or sufficient spacing exceptions for pointer targets [29]. Core Web Vitals guidance keeps CLS of 0.1 or less as the good visual-stability threshold [30].

Open-source tools already solve real pieces. Storybook can turn every story into a visual baseline [31]. Playwright can compare screenshots and ARIA snapshots [32], [33]. Argos and BackstopJS provide visual review and screenshot-diff workflows [34], [35]. Playwright and Storybook can run axe-based accessibility checks, while their docs warn that automation is only a first-line signal [36], [37]. Jankurai's role is to bind those outputs to route, viewport, browser, hashes, rule IDs, selector, severity, owner, and witness decision.

Pixel QA is first-class but not exhaustive on every pull request. Critical flows, high-risk UI surfaces, visual diff baselines, payments, auth, admin actions, onboarding, and canvas/3D surfaces need browser-step proof in the PR lane. Full viewport and device matrices belong in nightly or release lanes unless the changed path directly touches those surfaces.

IX. Security, Supply Chain, and Permissions

Agentic coding expands the write surface. The security posture must therefore be structural. CISA/NSA guidance pushes memory-safe languages as a way to reduce memory-related vulnerability classes [38]. Veracode's GenAI security results show syntax success does not imply secure code [3]. GitGuardian's secret-sprawl evidence shows AI-churned repositories need stronger secret gates, not more trust [4].

A. Security Considerations

Jankurai evidence can itself become sensitive. A conformant implementation MUST treat logs, screenshots, traces, prompts, browser storage, dependency reports, and security scan output as evidence with privacy rules, not as disposable CI noise. Evidence bundles should avoid secrets by construction, redact customer data, hash large binary artifacts, separate public and restricted receipts, carry retention metadata, and fail release when required redaction status is missing.

Permission policy should be boring. Agents should not receive broad filesystem, network, or credential access merely because a task is urgent. High-risk actions need named lanes and evidence: dependency install, secret material, generated-zone writes, migrations, release artifacts, and browser automation against privileged surfaces. Missing tools are not silently green: doctor diagnostics and security evidence record whether a tool was absent, advisory, failed, or blocking. `--strict` turns policy-blocking security status into a failing lane.

X. Waivers, Observability, and Repair Receipts

This paper reserves *exceptions* for runtime or program errors. Standards deviations are *waivers*: named, scoped, owned, testable, and temporary departures from a required control. A waiver is not a suppression. A suppression hides or mutes a finding. A compensating control accepts a different proof mechanism for the same risk. A waiver records why the normal control cannot be satisfied yet, which compensating control applies, and when the risk must be repaired or renewed.

Waiver lifecycle states are `proposed`, `active`, `renewed`, `expired`, `closed`, and `superseded`. Active waivers require owner approval, scope, reason, proof requirements, residual risk, expiry, and repair plan. Expired waivers fail closed in ratchet and release modes.

Runtime exceptions still matter for repair. HTTP APIs should use RFC 9457 problem details for boundary errors [42]. Observability should emit OpenTelemetry exception attributes such as exception type, message, stack trace, and error type [43], [44]. TypeScript can preserve underlying causes with `Error.cause` [45]. Rust should prefer typed errors for domain/application code, using context wrappers only at boundaries where opaque provider detail is acceptable [46], [47].

Every controlled error that can reach logs, API responses, background jobs, or tests should expose a stable name, stable code, purpose, reason, common fixes, documentation URL, safe user message, correlation ID, and source cause when safe. The point is not verbosity. The point is to make a failing test or production trace directly actionable for the next agent.

Repair is a governed loop, not permission for unattended mutation. `jankurai repair-plan` reads audit output and turns findings into ordered, schema-validated candidate repairs. `jankurai repair --dry-run` produces a receipt without touching the repository. Real application is gated behind explicit environment variables, bounded risk, and reviewed flags; git commits, pushes, and draft PR creation require separate opt-ins. Jankurai can prepare a proof-backed

TABLE XII
RENDERED UX QA DETECTORS FOR A CONFORMANT PRODUCT SURFACE.

Detector	Machine signal	Merge behavior
Design-system constraints	Component imports, token use, no raw one-off spacing/color/z-index, Code Connect or equivalent mapping.	Block unapproved design-language drift.
Storybook state coverage	Normal, loading, empty, error, long text, locale, theme, mobile, role, and interaction states.	Require stories for reusable components and key screens.
Playwright visual proof	Component and flow screenshots under pinned browser, font, viewport, timezone, and locale settings.	Require review for protected baselines.
DOM geometry rules	Bounding boxes, computed styles, scroll sizes, target spacing, overlap, clipping, wrapping, nested scrollbars, and fixed/sticky collisions.	Block objective layout failures before human QA.
Accessibility structure	axe/WCAG checks, ARIA snapshots, keyboard paths, focus visibility, form labels, and target size.	Block critical known violations; route ambiguous cases to expert review.
Layout stability	CLS and late-shift evidence from Lighthouse or Web Vitals.	Block severe movement on product-critical pages.
AI/CV triage	Semantic review of ambiguous visual deltas and screenshot crops.	Warn or route to humans; do not replace deterministic gates.
Human feedback loop	Labels for true defect, intentional change, false positive, acceptable variance, missing rule, or design-system bug.	Improve thresholds, baselines, stories, and future rules.

TABLE XIII
PERMISSION RECEIPT MATRIX.

Permission surface	Allowed evidence	Blocking concern
Repo reads	Changed-path inventory, source-trust labels, context-pack receipt.	Reading secrets, private transcripts, or unrelated customer data into context.
Tracked writes	Owner route, changed paths, test-map lane, proof receipt.	Writes outside declared scope.
Generated zones	Source contract path, generator command, artifact digest.	Hand-edited generated output.
Dependency install	Lockfile diff, rationale, SCA/OSV result, SBOM/provenance.	Unreviewed package drift or install script risk.
Network	Destination, purpose, lane, timeout, cache policy.	Unbounded exfiltration or live-service dependence in proof.
Secrets	Named secret broker, redaction proof, no raw value in artifacts.	Secret material in prompts, logs, screenshots, or fixtures.
Migrations	Migration analysis, rollback/backfill/lock proof, DB lane receipt.	Destructive migration without safety evidence.
Privileged browser automation	Route, account class, storage isolation, screenshot redaction.	Capturing private state or bypassing auth controls.
Push/PR	Branch name, diff scope, proof summary, reviewer route.	Publishing unreviewed or out-of-scope changes.
Auto-merge	Out of scope for this edition.	Merge without current witness and human/CI policy gate.

branch, commit, and draft PR, but high-risk autonomous mutation and auto-merge remain outside the standard.

XI. MIGRATION, VERSIONING, AND GOVERNANCE

Teams do not reach conformance through rewrite fantasy. They move by shrinking ambiguity. First add the audit in advisory mode. Then add root instructions, owner maps, test maps, generated zones, version manifests, and proof lanes. Then generate contracts, isolate data access, declare durable-truth ownership, and add rendered UX/security evidence for critical paths. Only after the repo can route and prove changes should teams accelerate agent-driven migration.

First-hour adoption must be no-write unless the operator explicitly applies a reviewed plan. `jankurai adopt --mode observe` and `jankurai init --dry-run` produce adoption or init artifacts without claiming conformance by accident. Migration analysis carries liability forward instead of hiding it: `jankurai migrate --analyze` records missing tests, direct database risk, contract drift, and stack-distance evidence so a brownfield repo can improve by slices.

TABLE XIV
SECURITY CONTROLS FOR AGENT-NATIVE REPOSITORIES.

Risk	Control	Repair evidence
Prompt injection and hostile context	Source hierarchy: root instructions, local owner rules, trusted docs, then untrusted issue/web text.	Receipt names ignored instruction, trusted rule, and resulting safe action.
Secrets and credentials	Secret scanning, no secrets in UI or docs, redacted logs, no model prompt leakage.	Scanner artifact, redaction test, finding closure.
Dependency sprawl	Lockfiles, SCA, SBOM/provenance, dependency rationale for new packages.	Package diff, risk reason, scanner result [39]–[41].
Sandbox escape or tool overreach	Least-privilege tools, explicit write scope, generated-zone protections.	Changed-path report and policy decision.
Unsafe code and FFI	Unsafe ledger, boundary tests, memory-safety review where the stack exposes unsafe surfaces.	Ledger entry, invariant tests, owner approval.
False-green security	Security lane mapped by path and risk, not by agent choice.	CI job link and report artifact.
CI downgrade	Pin actions, minimize workflow permissions, require evidence uploads, and diff branch protections.	Workflow proof, permission diff, and release gate receipt.

TABLE XV
MINIMUM REPAIR RECEIPT FIELDS.

Field	Purpose
`receipt_id`	Stable identifier for the repair evidence.
`standard_version`, `auditor_version`, `schema_version`	Version bindings for interpretation.
`before_commit`, `after_commit`	Exact repair range.
`started_at`, `completed_at`	Timing evidence and repair half-life input.
`command_digest`, `log_digest`, `artifact_digests`	Replay and tamper evidence.
`decision`	`pass`, `review`, `block`, `ratchet_fail`, or `release_fail`.
`waiver_closed`	Whether a prior waiver was closed by the repair.
`residual_risk`, `redaction_status`	Remaining risk and evidence privacy state.
`owner_approval`	Owner route or approval receipt.
`expires_at`	Required when the repair is partial or waiver-backed.

TABLE XVI
SCHEMA COMPATIBILITY POLICY.

Change	Meaning
Patch	Clarification, copy fix, example correction, or non-semantic schema note.
Minor	Additive fields or advisory rules that preserve existing report interpretation.
Major	Breaking report, witness, receipt, or conformance semantics.

TABLE XVII
CONFORMANCE CLAIM TIERS.

Tier	Evidence
Self-attested	Repository emits local reports and witness artifacts.
CI-attested	Required CI uploads current receipts and merge witness for the commit.
Third-party-attested	Independent implementation or auditor reruns the suite and verifies artifacts.
Registry-listed	Public registry records version, level, evidence bundle, expiry, and compatibility.

Governance needs a standard process, not private taste. Jankurai should use a JEP/RFC process for rule assignment, rule lifecycle, compatibility policy, badge policy, security disclosure, independent implementation certification, and old schema support. Rule lifecycle states are `draft`, `candidate`, `implementation-evidence`, `stable`, `superseded`, and `obsolete`. Draft rules need examples and fixtures. Candidate rules need implementation evidence. Stable rules need schema-backed output, documented repairs, and regression tests.

Public evidence uses the same discipline. `registry` and `cell` expose reusable primitives; `bench`, `certify`, `govern`, and `publish` produce versioned benchmark, certification, governance, badge, and public-evidence artifacts. Those artifacts only matter because `agent/standard-version.toml` binds them to a standard version, auditor version, schema version, paper edition, and manifest profile label. `paper_edition` is provenance for the paper, not a core conformance field.

Streaming migration follows the same governance. Do not begin by replacing Kafka. Begin by hiding event buses behind contracts and adapters, measuring broker readiness with replay

TABLE XVIII
CI ADOPTION MODES.

Mode	Merge behavior
Advisory	Emit JSON/Markdown reports and never block.
Guarded	Block critical caps and malformed output.
Standard	Block high and critical findings plus required receipts.
Ratchet	Prevent score or finding regression without a dated waiver.
Release	Gate shipped artifacts on audit, tests, security, contracts, DB, e2e, versions, and release evidence.

and compatibility tests, and making the migration path visible in `agent/boundaries.toml`. Streaming clients belong behind adapters and generated event contracts; the broker choice is profile evidence, not Jankurai Core.

Governance should separate empirical claims from policy choices. Scoring weights, hard caps, conformance levels, RPNs, reference-profile scores, and rule IDs are versioned policy. Public source claims require citations. New audit output fields require schema versioning. Breaking compliance changes require migration notes and example repairs. The goal is not to freeze one 2026 opinion forever; it is to make the standard itself updatable without letting every repository invent a private dialect.

XII. Languages as Proof-Cost Compression

Programming language history is often told as a progression toward abstraction. For Jankurai, the more useful lens is proof cost. A language or framework decides which burdens move from human memory into syntax, type systems, runtimes, libraries, tooling, and conventions. Machine code compressed nothing. Assembly compressed opcodes into names. Fortran compressed scientific arithmetic. COBOL compressed business records. C compressed portable systems programming into a thin abstraction over hardware. Java and .NET compressed memory management and enterprise portability into managed runtimes. Python compressed exploration and glue. TypeScript compressed large-team JavaScript maintenance by adding a static feedback loop to the browser ecosystem, a direction now strengthened by Microsoft's native TypeScript 7 effort [48].

The agent-era lesson is that syntax is no longer the scarce resource. A model can imitate syntax. It cannot reliably infer unstated ownership, hidden waiver policy, or tribal boundaries. The language and repository must make invalid paths structurally harder and repair locality easier.

XIII. Technical Promise Versus Standard Gravity

New languages emerge when an existing compression package stops matching the dominant pain. They fracture around runtime ceilings, ecosystem gaps, tooling weakness, migration cost, hiring constraints, interop friction, and fashion that lacks enforcement. A language can be technically excellent and still fail as a default company architecture if it lacks the operational surround: boring deployment, security scanning, observability, package maturity, database migration norms, and enough public examples for agents and humans to learn from.

Julia is the cleanest example of legitimate promise without universal default status. Its multiple dispatch, JIT compilation, and scientific-computing focus attack the two-language problem in numerical work: prototype in a high-abstraction language, then rewrite hot paths in C, C++, or Fortran [50]. That is a real problem, and Julia remains a serious answer for many scientific domains. The adoption lesson is not that Julia is bad. The lesson is that solving an inner-loop expression problem does not automatically solve company-scale proof routing, repair locality, cloud operations, security review, hiring, packaging, and cross-language contract discipline.

The shelf is not a graveyard of bad ideas. It is evidence that technical elegance and default-standard status are different things. Jankurai Core does not choose a language. It asks whether the chosen language and ecosystem can emit owner routes, proof receipts, generated-zone evidence, and merge witnesses cheaply enough to reduce drift over time.

XIV. Non-Normative Reference Profile Score

This section is non-normative. The Jankurai standard is stack-neutral: a Go, JVM, .NET, Python, Rails, Elixir, or TypeScript-heavy repository can conform if it emits equivalent owner routing, proof receipts, generated-zone evidence, and merge witnesses. The Reference Profile Score below is an aid for durable product systems maintained by agents and humans together. It deliberately weights correctness, security, contracts, and repairability above first-draft velocity because AI already lowers the cost of plausible drafts. The weights in this edition are policy assumptions, not universal empirical truth.

The scoring model is not required to implement Jankurai Core and MUST NOT reject an otherwise conformant alternate profile.

Points are awarded only for structural properties. "We review carefully" is not a security control. "The senior engineer knows where SQL belongs" is not a boundary. "The README explains it" is not a generated contract. A reference profile should make the wrong path hard to express and the right path cheap to prove.

Hard filters apply before points. A profile with no deterministic local proof lane, no security lane for high-risk changes, no generated contract discipline, or no credible data boundary cannot be recommended even if it is pleasant to write. These caps are policy bands and should be recalibrated against incident data, repair time, false positives, and review burden.

XV. Reference Profile Comparison

The comparison below is illustrative, policy-weighted, and non-normative. The standard is the merge witness and conformance artifact boundary, not a stack ranking. The scores assume durable product systems with web product surface, API/service behavior, operational security requirements, and

TABLE XIX
LANGUAGE EVOLUTION AS PROOF-COST COMPRESSION.

Era or family	Human bottleneck compressed	Repository-alignment interpretation
Machine code and assembly	Remembering opcodes, addresses, registers, and jumps.	Exactness without reviewability is not enough; merge evidence needs semantic structure.
Fortran and COBOL	Expressing domain work without writing every machine operation.	Domain vocabulary matters because owners and proof lanes need stable concepts.
C and Unix systems programming	Portable control over hardware, memory, and operating-system interfaces.	Power without structural memory safety increases audit burden; CISA/NSA guidance pushes teams toward memory-safe defaults [38].
Java and .NET	Managed memory, deployment portability, enterprise libraries, and tooling.	Mature ecosystems help when boundaries and contracts are explicit.
Python, R, Julia	Exploration, data analysis, notebooks, and scientific productivity.	Excellent for model/data loops; risky when unbounded into durable product truth. Python 3.14 improves runtime options, but not the boundary problem [49].
JavaScript and TypeScript	Browser programming, product velocity, and typed frontend maintenance.	Essential product surface; durable backend truth still needs explicit ownership and proof.
Rust and modern safe systems languages	Memory safety, ownership, concurrency discipline, and explicit error handling.	Strong reference-profile core because many invalid states can be rejected before runtime.

TABLE XX
TECHNICAL PROMISE VERSUS STANDARD GRAVITY.

Language or ecosystem	Real promise	Adoption limiter	Alignment penalty
Julia	Scientific productivity with performance-oriented multiple dispatch.	Broader product engineering ecosystem and deployment defaults lag dominant stacks.	Thinner general-product corpus and more local conventions.
D	Better C++-class systems ergonomics.	Could not displace entrenched C/C++ ecosystems and tooling gravity.	Smaller examples and weaker enterprise defaults.
Nim and Crystal	Python/Ruby-like ergonomics with native compilation.	Smaller communities, fewer boring production patterns.	Agents get fewer canonical examples and fewer tool-enforced boundaries.
Elm	Frontend reliability and no-runtime-exception ambition.	Ecosystem and interop constraints limited broad adoption.	Excellent lessons, but narrow hiring and corpus surface.
F# and Clojure	High-leverage functional design on mature runtimes.	Strong niches, smaller mainstream product footprint.	Expert-friendly abstractions can become opaque to repair agents.
Haskell and Scala	Powerful type-system and abstraction research translated to production niches.	Complexity and hiring/training friction.	Proof power helps only when conventions are explicit and common.
Elixir/Phoenix	Fault tolerance, supervision, realtime systems on the BEAM.	Specialist fit rather than universal product default.	Excellent realtime profile when equivalent proof receipts and witnesses exist.

long-running maintenance by agents and humans together. Alternative stacks can conform when they produce equivalent proof receipts and merge witnesses.

The scoring model is not required to implement Jankurai Core and MUST NOT reject an otherwise conformant alternate profile.

Sensitivity is concentrated in three weights: memory safety/security, ecosystem corpus strength, and runtime/concurrency. Increase ecosystem weight and Go, .NET, and JVM improve. Increase type-state and memory-safety weight and Rust separates. Increase product velocity and full-stack TypeScript rises, but it hits hard filters unless durable truth, generated contracts, and server ownership are explicit. These scores are reproducible from stated assumptions, not empirical universals.

Detailed streaming comparisons do not belong in the main conformance line. The core rule is short: streaming clients belong behind adapters and generated event contracts. Kafka, Tansu, Iggy, Fluvio, NATS, Redis Streams, or equivalent systems can be profile choices when they emit replay, compatibility, security, observability, and migration evidence. The broker must not become hidden stack identity.

XVI. REFERENCE ARCHITECTURE PROFILE

The Rust/TypeScript/PostgreSQL profile is a reference architecture, not the definition of Jankurai conformance. It gives agents one concrete map, audit one concrete policy, and CI one

TABLE XXI
NON-NORMATIVE JANKURAI REFERENCE-PROFILE SCORING RUBRIC.

Criterion	Weight	Full-credit signal	Evidence and argument
Agent-verifiable correctness loop	18	Fast type/compile checks, deterministic test routing, generated contracts, property tests, reproducible local and CI lanes.	AI output must be treated as suspect until a proof loop rejects or accepts it; setup and context benchmarks show environment and retrieval reliability are central bottlenecks [15], [16].
Security, memory safety, supply chain	16	Memory-safe core, secret scanning, SCA, SBOM/provenance, lockfiles, unsafe ledger, dependency rationale.	CISA/NSA memory-safety guidance, Veracode GenAI findings, and GitGuardian secrets evidence all push security into structural gates [3], [4], [38].
Runtime performance, memory, cloud cost	13	Efficient hot path, predictable latency, bounded memory, cheap concurrency, low cold-start cost.	Agent-era systems are compute-heavy and parallel; runtime cost becomes architectural, not cosmetic.
Concurrency and resilience	12	Structured async, cancellation, backpressure, idempotency, retries, dead-letter handling, replayable workflows.	Go survey evidence shows broad AI use but persistent quality concerns; concurrency needs guardrails rather than cleverness [51].
Boundary and contract integrity	11	OpenAPI/Protobuf/JSON Schema sources, generated clients, schema drift checks, migration gates.	Cross-language systems work only when contracts are generated and tested; OpenAPI Generator and Buf provide mature paths [52], [53].
Simplicity and review surface	10	Small files, narrow modules, explicit ownership, boring dependency direction, low duplication.	Agents over-edit when boundaries are implicit; SWE-agent and SWE-bench show interfaces and environment shape affect agent results [23], [24].
Ecosystem, hiring, AI corpus strength	8	Large corpus, maintained packages, common deployment patterns, strong model familiarity.	GitHub Octoverse language patterns and TypeScript's rise matter because public examples are part of the agent substrate [1].
Observability, auditability, provenance	6	OpenTelemetry traces/metrics/logs, request IDs, release provenance, repair receipts.	OpenTelemetry gives a vendor-neutral vocabulary for post-merge repair [43], [54].
Data integrity and durable workflow fit	4	PostgreSQL constraints, migrations, indexes, RLS where useful, transactional workflow safety.	PostgreSQL constraints and row-security policies move durable truth below fallible application code [55], [56].
Product velocity and interop	2	Fast UI loop, generated clients, easy local dev, standard browser ecosystem.	TypeScript 7 and Vite 8 improve feedback speed, but velocity is deliberately weighted below proof [48], [57].

TABLE XXII
REPRESENTATIVE HARD CAPS BEFORE WEIGHTED SCORING.

Missing or unsafe control	Max score
No deterministic local proof lane	65
No security lane on high-risk repo	60
No generated contract discipline for public boundary	80
Direct DB access from wrong layer	66
No secret or dependency scanning in CI	78
Prompt injection or overbroad agent agency in trusted policy	65–78
No rendered UX proof for user-facing web surface	84
False-green tests or destructive migration without safety evidence	70–76

TABLE XXIII
REFERENCE PROFILE SCORE BANDS UNDER THE JANKURAI SCORING MODEL.

Profile family	Score band
Rust core + TypeScript/React/Vite + PostgreSQL	91–97
Go services + TypeScript/React/Vite + PostgreSQL	86–94
C#/.NET + TypeScript/React/Vite + PostgreSQL	85–93
TypeScript product plane + Rust/Go compute cells + PostgreSQL	82–94
Kotlin/Java JVM + TypeScript/React/Vite + PostgreSQL	82–92
Rails, Python/FastAPI, or Elixir/Phoenix with strong boundaries	72–90

concrete set of gates for projects that choose this profile. Other profiles can conform when they preserve the same ownership, proof, generated-boundary, security, UX, and witness artifacts.

The filesystem should be a routing table. In the reference profile, a patch touching a payment invariant should land in Rust domain/application and database constraints. A patch touching a form should land in TypeScript UI and generated client contracts. A patch touching model behavior should land in the bounded AI/data service and contract tests. If the agent must infer ownership from convention, the repo has already failed.

An alternate conformant profile can replace the implementation spine. A Go service profile might use `cmd/`, `internal/domain/`, `internal/app/`, `internal/adapters/`, `api/`, and `migrations/`.

TABLE XXIV
REPRESENTATIVE SCORE DECOMPOSITION. BANDS EXPRESS POLICY UNCERTAINTY, NOT STATISTICAL CONFIDENCE.

Stack family	Proof	Sec.	Runtime	Boundary	Ops	Band	Conformance logic
Rust + TS/Vite + Postgres	18	16	13	11	36	± 3	Reference default when no stronger domain constraint exists.
Go + TS/Vite + Postgres	16	13	13	10	38	± 4	Strong cloud-service profile where simplicity beats type-state power.
.NET + TS/Vite + Postgres	16	13	12	10	38	± 4	Strong regulated enterprise answer when Microsoft platform fit speeds proof.
Full-stack TypeScript + Postgres	13	10	9	8	36	± 6	Conformant when server ownership, generated contracts, and durable truth boundaries are explicit.
Python/FastAPI + Postgres	10	8	8	7	34	± 7	Conformant as durable core only with strong ownership, DB constraints, security, and generated contracts.
Rails + Postgres	11	9	8	7	36	± 6	Fast CRUD fit; can conform with generated contracts, policy-backed service boundaries, and release receipts.
Elixir/Phoenix + Postgres	14	11	11	8	37	± 5	Specialist override for realtime collaboration and supervision-heavy systems.
JVM/Spring or Kotlin + Postgres	15	11	11	10	40	± 5	Brownfield and enterprise fit can outweigh default-profile migration cost.

It can claim Jankurai conformance when those paths emit equivalent owner routes, proof receipts, generated-zone evidence, security evidence, UX evidence where applicable, and merge witnesses. The standard follows the evidence, not the mascot stack.

```
[CORE]
AGENTS.md
agent/
  owner-map.json
  test-map.json
  generated-zones.toml
  standard-version.toml
  proof-lanes.toml
```

```
[PROFILE]
apps/web/          TS/React UI
apps/api/          Rust edge
crates/domain/     invariants
crates/adapters/ DB/queues/APIs
contracts/         OpenAPI/Proto
db/                migrations
```

```
[EVIDENCE]
agent/repo-score.json
agent/repo-score.md
target/jankurai/
  merge-witness.json
  evidence-index.json
  receipts/
```

Fig. 3. Three spines: core control spine, reference profile implementation spine, and evidence output spine. Only the control and evidence interfaces are required by Jankurai Core.

TABLE XXV
REPRESENTATIVE OWNERSHIP CELLS FOR THE REFERENCE PROFILE.

Cell	Owns	Must not own
`apps/web`	React UI, route state, forms, local validation, generated API clients, Playwright tests.	Secrets, durable truth, direct SQL, core authorization, handwritten API mirrors.
`apps/api`	Rust HTTP/RPC edge, request normalization, auth middleware, idempotency keys, response shaping.	Domain invariants hidden in handlers, scattered SQL, UI concerns.
`domain` crate	IDs, value objects, invariants, state machines, pure decisions, stable error types.	I/O, env reads, network, filesystem, database clients, framework code.
`application` crate	Commands, authz, transaction orchestration, idempotency, workflow use cases.	Transport details, SQL drivers, UI state, prompt/model logic.
`adapters` crate	PostgreSQL access, queue/streaming clients, external APIs, filesystem, environment, provider clients.	Domain rules, authorization policy, or event schema ownership.
`contracts`	OpenAPI, Protobuf, JSON Schema, generated stubs and clients.	Hand-edited generated outputs or business logic.
`db`	Migrations, constraints, indexes, RLS, seed rules, schema snapshots.	Application orchestration or hidden business process.
`python/ai-service`	Inference, embeddings, evals, prompt experiments, offline transforms, typed AI API.	Product truth, authz, billing, direct production DB ownership.
`ops`	CI, release, telemetry, secret scanning, SBOM/SCA, provenance, policy gates.	Feature behavior hidden behind manual operations.

XVII. Related Work

AI coding benchmarks and agents measure task completion, environment use, and agent-computer interfaces. Supply-chain standards secure artifacts and dependencies. API/schema standards define contract surfaces. Conformance ecosystems show how standards become adoptable. Agent instruction surfaces are emerging as repository policy. UX, accessibility, observability, and proof-output ecosystems provide the receipts.

Jankurai's contribution is the binding layer: it turns existing outputs into a versioned, repository-local merge witness.

XVIII. Limitations and Research Agenda

Jankurai does not prove full semantic correctness. A merge witness can show that changed paths were routed to owners, required proof lanes ran, receipts exist, and missing evidence was handled; it cannot prove every business invariant or exclude malicious compiler, runtime, or organizational governance compromise. Current evidence is conformance-oriented and repository-local. The reference implementation is young, some detectors are advisory or partial, and signed receipts, transparent evidence logs, cross-repo federation, and organizational trust remain future work.

A. Threats to Validity

The taxonomy may reflect source-material bias. Detectors may have false positives and false negatives. Partial rows can be overinterpreted as stronger coverage than they deserve. Reference-profile scoring can bias readers toward Rust/TypeScript/PostgreSQL even when another stack can conform. Browser evidence is environment-sensitive. Screenshots, logs, and traces can leak secrets if redaction fails. Scores can be gamed. Compliance theater can produce artifacts without improving engineering. CI cost can become excessive. Small repositories may need a thinner profile than the paper emphasizes.

B. Failure Modes of Jankurai Itself

Jankurai can fail as artifact theater: reports exist but nobody trusts or uses them. Maps can go stale. Receipts can be faked or copied. Proof lanes can become flaky. Adapters can drift. Reference-profile guidance can harden into stack dogma. Ceremony can overload small changes. These are not reasons to abandon conformance; they are reasons to keep proof freshness, receipt validity, waiver expiry, seed fixtures, and independent implementation tests central.

The strongest version of the criticism is useful: a standard can become ceremony, and a reference profile can become dogma. Jankurai should be judged by whether it improves

TABLE XXVI
ADJACENT ECOSYSTEMS AND JANKURAI'S BOUNDARY.

Area	Representative work	Jankurai distinction
Agent benchmarks and agents	SWE-bench, SWE-agent, OpenHands, Aider, SetupBench, ContextBench [15], [16], [23]–[26].	Standardizes the repository-local merge decision those agents must satisfy.
Supply-chain standards	SLSA, SPDX, OSV, OpenSSF Scorecard [8], [12], [40], [41].	Uses evidence mechanics at the pull-request boundary: changed paths, owners, receipts, missing evidence, and witness decisions.
API and schema standards	OpenAPI, OpenAPI Generator, Protocol Buffers/Buf, JSON Schema [9], [52], [53], [58], [59].	Treats contracts as inputs to merge conformance rather than as the whole standard.
Conformance ecosystems	W3C process and Kubernetes conformance [10], [11].	Applies maturity states, levels, fixtures, and submitted evidence to repository merge.
Agent instruction surfaces	`AGENTS.md`, Codex guidance, Claude memory, Cursor rules, Copilot instructions [17]–[21].	Routes instruction surfaces through one conformance model so adapters cannot drift from proof lanes.
UX and observability evidence	Playwright, Storybook, WCAG, OpenTelemetry, JUnit, SARIF [27], [29], [31], [32], [37], [54], [60].	Binds disconnected logs, screenshots, traces, and findings into evidence bundles and merge witnesses.
Repository ownership and policy	CODEOWNERS-style review, policy-as-code, reproducible build tools.	Combines ownership, proof routing, generated zones, permissions, receipts, and repair queues as one versioned repository interface.

TABLE XXVII
CONCRETE FUTURE WORK FOR JANKURAI.

Lane	Expected artifact
Public conformance suite	Runnable tests, fixtures, expected JSON/Markdown reports, and versioned pass criteria.
Hosted or static evidence registry	Immutable evidence bundles, badges, score history, and current/previous standard metadata.
Signed proof receipts and attestations	Artifact digests, command receipts, provenance, and verification command.
Benchmark corpus for repair locality	Repos, patches, route plans, expected lanes, repair time, and escaped-defect labels.
Token-budget optimizer	Short root routers, path-scoped policy packs, symbol/repo maps, filtered command receipts, generated context packs, evidence indexes, stale-doc pruning, and deterministic proof routing.
Context-pack minimizer	Trust-labeled packs with measured token cost, recall, and false-exclusion rates.
Cross-agent adapter conformance tests	Codex, Claude, Cursor, Copilot, terminal-agent, hook, and MCP adapter fixtures.
UI geometry oracle hardening	Viewport matrices, screenshot crops, ARIA snapshots, layout rules, and false-positive corpus.
Semantic rule detector expansion	Fixtures and negative tests for authz, input boundaries, cost controls, release readiness, and human-review evidence.
Waiver and exception libraries	Runtime exception templates plus standards-waiver templates with docs links and repair hints.
Cost-budget and kill-switch tooling	Spend limits, quotas, stop conditions, alerts, and receipt-backed emergency controls.
Reusable cell registry and certification	Cell manifests, install plans, proof lanes, benchmark receipts, and certification policy.

repair locality, reduces unsafe merges, shortens review cycles, reduces vibe-artifact density, and produces better evidence. If a team can prove those outcomes with a different stack and a compatible control plane, the profile should be documented and studied.

XIX. CONCLUSION

Agent-native engineering is an adaptation problem. Teams that optimize only for generation will get faster at creating ambiguity. Teams that optimize for verification will get faster at rejecting bad code, localizing mistakes, repairing real failures, and changing architecture without guessing.

The durable contribution is not a stack ranking. It is the merge witness, the proof receipt, and the reproducible merge decision. Jankurai asks a repository to make conformance concrete: changed paths, owner route, required proof, observed evidence, missing-evidence decision, artifact digests, commit identity, and tool identity. Generation is cheap; reproducible merge evidence is the new standard. Anything less is faster vibe coding.

TABLE XXVIII
COMPACT RULE METADATA REGISTRY.

Rule	Family	Required at	Fixture status	Receipt type	Detector maturity
HLT-001	Dead markers / entropy	HL2	detector-backed	fast/audit	deterministic
HLT-002	Generated mutation	HL2	seeded fail	contract	deterministic
HLT-003	Ownerless path	HL2	seeded fail	audit	deterministic
HLT-004	Unmapped proof	HL2	seeded fail	proof plan	deterministic
HLT-005	Product truth in wrong boundary	HL3	mapped	owner/db	heuristic
HLT-006	Direct DB wrong layer	HL3	mapped	db	heuristic
HLT-007	Handwritten contract	HL3	mapped	contract	heuristic
HLT-008	False-green risk	HL3	mapped	fast/release	evidence-routed
HLT-009	Generated security	HL3	mapped	security	evidence-routed
HLT-010	Secret sprawl	HL2	seeded fail	security	deterministic
HLT-011	Prompt injection	HL3	mapped	security	heuristic
HLT-012	Overbroad agency	HL2	seeded fail	permission	heuristic
HLT-013	Rendered UX gap	HL3	seeded fail	web/ux	evidence-routed
HLT-014	Accessibility gap	HL3	mapped	web/a11y	evidence-routed
HLT-015	Context setup gap	HL2	mapped	fast/context	heuristic
HLT-016	Supply-chain drift	HL3	mapped	security	evidence-routed
HLT-017	Opaque observability	HL3	mapped	observability	evidence-routed
HLT-018	Perf/concurrency drift	HL4	mapped	release	evidence-routed
HLT-019	Streaming runtime drift	HL3	mapped	contract/obs.	heuristic
HLT-020	CI hardening gap	HL3	mapped	security/ci	heuristic
HLT-021	Destructive migration	HL2	seeded fail	db	deterministic
HLT-022	Authz isolation gap	HL3	seeded fail	db/security	evidence-routed
HLT-023	Input boundary gap	HL3	seeded fail	security	evidence-routed
HLT-024	Agent-tool supply gap	HL3	mapped	security	governance-backed
HLT-025	Release readiness gap	HL5	mapped	release	governance-backed
HLT-026	Cost budget gap	HL4	mapped	budget	governance-backed
HLT-027	Human-review evidence gap	HL3	mapped	review	evidence-routed

TABLE XXIX
REPRESENTATIVE RULE REPAIRS.

Rule ID	Required evidence	Default repair
HLT-002-GENERATED-MUTATION	Generated path, source path, regeneration command, diff context.	Change the source contract or generator and regenerate.
HLT-003-OWNERLESS-PATH	Changed path with no owner-map match.	Add owner-map entry or move code into owned path.
HLT-004-UNMAPPED-PROOF	Changed path with no test-map lane.	Add or select deterministic proof command.
HLT-010-SECRET-SPRAWL	Secret-like value, broad env dump, unsafe fixture, prompt transcript leak, or missing secret scan.	Remove secret, rotate if needed, add scanner evidence and redaction tests.
HLT-012-OVERBROAD-AGENCY	Agent/tool lane allows broad shell, browser, network, migration, delete, or credential actions.	Add least-privilege permission profile and approval gate.
HLT-013-RENDERED-UX-GAP	User-facing UI change lacks screenshot, trace, geometry, baseline, or viewport proof.	Add Storybook/Playwright/geometry evidence for changed surface.
HLT-021-DESTRUCTIVE-MIGRATION	Destructive SQL under migration paths without rollback, backfill, lock, or DB proof evidence.	Add migration safety evidence or replace with a non-destructive transition.
HLT-022-AUTHZ-ISOLATION-GAP	Authorization, RLS, tenant, or role surfaces lack owner/non-owner negative proof.	Add role matrix, RLS, and cross-user denial tests.
HLT-023-INPUT-BOUNDARY-GAP	Unsafe input boundary, dynamic execution, string SQL, shell, fetch, or rendering sink lacks negative proof.	Add schemas, parameterization, allowlists, sandboxing, and exploit fixtures.

APPENDIX A
RULE IDS AND CONFORMANCE EVIDENCE

Stable rule identifiers make audit output durable enough for repair agents, CI annotations, release notes, and independent conformance tests. The compact registry below is the public shape; detailed row coverage remains in `agent/vibe-coverage.toml` and generated reports.

A. Vibe-Coding Source Coverage

Jankurai 0.7.0 maps every parsed row from `tips/vibe_coding/tip1.txt` through `tip5.txt` into `agent/vibe-coverage.toml`. Coverage is detector-backed only when a narrowed row has deterministic rule coverage plus proof/report evidence; partial when Jankurai has a reviewed control family but still needs issue-specific fixture, CI, or governance receipt evidence. The full per-row registry is supplemental source material in `agent/vibe-coverage.toml`; generated machine-readable outputs are emitted under `target/jankurai/` by the documented coverage command.

TABLE XXX
COMPACT VIBE-CODERAGE REGISTRY SUMMARY FOR V0.7.0.

Status or family	Count	Interpretation
Source rows mapped	260	Every parsed row from `tips/vibe_coding/tip1.txt` through `tip5.txt` has one canonical issue.
Detector-backed	17	Narrow issue families with deterministic detector evidence and audit/report artifacts.
Partial	243	Reviewed control families that still require issue-specific fixture, CI, or governance evidence.
Unmapped / none	0	No source rows are intentionally left without a control-family mapping in this release.
Security TLR rows	117	Largest source bucket; includes secrets, prompt injection, agency, supply chain, and input/security boundaries.
Verification TLR rows	61	Includes false-green tests, UI/a11y proof, and destructive/release checks that route through proof lanes.
Business-truth TLR rows	24	Includes authorization, data isolation, and state-machine correctness risks.

APPENDIX B
VERSIONED ARTIFACT MANIFEST

The canonical manifest is `agent/standard-version.toml`. It binds the paper source, rendered paper, agent Markdown companion, full coding standard, and agent standard brief. `target_stack` is the current manifest's profile label; emitted conformance/report/profile claims use `target_stack_id`.

```
standard = "jankurai"
standard_version = "0.7.0"
paper_edition = "2026.05-ed7"
auditor_version = "0.7.0"
schema_version = "1.5.0"
target_stack = "rust-ts-vite-react-postgres-bounded-python"
published = "2026-05-04"
release_tag = "v0.7.0"
supersedes = "v0.6.x"
compatibility = "schema minor-compatible"
license = "project license"

[[artifact]]
id = "paper-source"
path = "paper/jankurai.tex"
kind = "tex-wrapper"
version_field = "paper_edition"
schema_path = "n/a"
source = "paper/tex/"
command = "just paper"
generated = false
canonical = true
sha256 = "sha256:..."

[[artifact]]
id = "paper-render"
path = "paper/jankurai.pdf"
kind = "pdf"
version_field = "paper_edition"
source = "paper/jankurai.tex"
command = "just paper"
generated = true
canonical = false
sha256 = "sha256:..."
```

`cargo run -p jankurai -- versions` verifies that `VERSION`, `crates/jankurai/Cargo.toml`, CLI constants, standard documents, companion Markdown, artifact bindings, and generated-zone registration agree.

APPENDIX C
WAIVER AND REPAIR TEMPLATES

Waivers are allowed only when they are named, scoped, owned, testable, and temporary enough for an agent to repair later. Runtime exceptions are program errors; standards deviations are waivers.

```
---
id: WVR-YYYY-NNN
state: proposed | active | renewed | expired | closed | superseded
owner: <team or owner cell>
scope:
  - <exact file, crate, service, contract, or zone>
standard_version: "0.7.0"
auditor_version: "0.7.0"
schema_version: "1.5.0"
reason: <why the normal standard cannot be followed now>
compensating_control: <alternate evidence or manual gate>
required_proof:
```

```
  - <test-map lane name and command>
residual_risk: <bounded risk statement>
expires_at: <date or measurable exit condition>
owner_approval: <receipt or reviewer>
---

# WVR-YYYY-NNN: <short name>

## Repair path
- <first bounded repair pattern>
- <second bounded repair pattern>
```

```
---
receipt_id: RPR-YYYY-NNN
standard_version: "0.7.0"
auditor_version: "0.7.0"
schema_version: "1.5.0"
before_commit: <sha>
after_commit: <sha>
started_at: <timestamp>
completed_at: <timestamp>
command_digest: sha256:...
log_digest: sha256:...
artifact_digests:
  agent/repo-score.json: sha256:...
decision: pass | review | block | ratchet_fail | release_fail
waiver_closed: <id or false>
residual_risk: <none or bounded risk>
redaction_status: clean | redacted | restricted
owner_approval: <receipt or reviewer>
expires_at: <required if partial>
---

# Repair receipt

Changed paths, proof lane, result, and next repair.
```

APPENDIX D
REFERENCE-PROFILE FILE TREE DIAGRAMS

The body uses short diagrams so the reader can see the intended shape without leaving the conformance argument. The expanded diagrams below are the reference-profile target shape for one default Jankurai repository. Names may vary, but ownership, proof lanes, generated zones, durable truth, and repair evidence should remain explicit.

```
repo/
  [PROFILE] apps/
    web/                          TypeScript/React/Vite UI
      src/
        app/                      routes, shells, providers
        components/               design-system composition only
        generated/                [GENERATED] API clients/contracts
        stories/                  Storybook state matrix
      playwright/                 [EVIDENCE] critical flows/screens
    api/                          Rust HTTP/RPC edge
  [PROFILE] crates/
    domain/                       pure invariants and policy
    application/                  use cases, authz, transactions
    adapters/                     DB, queues, external APIs
    workers/                      async jobs and projections
  [CORE] contracts/
    openapi/                      OpenAPI source
    proto/                        protobuf source
    jsonschema/                   emitted JSON Schema when needed
  [PROFILE] db/
    migrations/                   durable schema history
  [PROFILE] python/ai-service/    bounded AI/data boundary only
  [EVIDENCE] packages/ux-qa/      rendered UX geometry runtime
```

```
repo/
  [CORE] AGENTS.md                short root router
  [CORE] agent/
    JANKURAI_STANDARD.md          brief agent bootstrap
    owner-map.json                path -> accountable owner
    test-map.json                 path -> proof lane
    proof-lanes.toml              runnable validation commands
    generated-zones.toml          generated file policy
    standard-version.toml         versioned artifact manifest
    audit-policy.toml             local scoring and waivers
  [CORE] docs/
    agent-native-standard.md      full standard
    mission.md                    paper mission and scope
```

```
    testing.md                  lane doctrine
    waivers/                    named temporary deviations
    repair/                     repair receipts and artifacts
  [EVIDENCE] agent/repo-score.json
  [EVIDENCE] agent/repo-score.md
  [EVIDENCE] target/jankurai/
    merge-witness.json
    evidence-index.json
    receipts/
```

APPENDIX E
GOLDEN FIRST-HOUR COMMAND PATH

The command map below is operational documentation for agents. It is not a full CLI manual and not a claim that every repository should enable every lane on day one.

```
jankurai adopt . --profile auto --mode observe \
  --out target/jankurai/adoption-plan.json \
  --md target/jankurai/adoption-plan.md

jankurai init . --level agents --dry-run \
  --plan-json target/jankurai/init-agents.json
jankurai init . --level agents --yes

jankurai init . --level score --yes
jankurai audit . --mode advisory \
  --json target/jankurai/repo-score.json \
  --md target/jankurai/repo-score.md

jankurai lane . --changed README.md \
  --out target/jankurai/proof-plan.json \
  --md target/jankurai/proof-plan.md

jankurai prove . --changed README.md \
  --plan-out target/jankurai/proof-plan.json \
  --plan-md target/jankurai/proof-plan.md

jankurai witness . --changed-from origin/main \
  --baseline agent/repo-score.json \
  --out target/jankurai/merge-witness.json \
  --md target/jankurai/merge-witness.md
```

A. Failure Example

```
jankurai witness . --changed-from origin/main \
  --baseline agent/repo-score.json \
  --out target/jankurai/merge-witness.json

# Expected decision when a changed generated file lacks
# source regeneration proof:
# decision = "block"
# missing_evidence = ["contract_receipt"]
# repair_queue[0].rule_id = "HLT-002-GENERATED-MUTATION"
```

REFERENCES

[1] GitHub, "Octoverse: A new developer joins GitHub every second as AI leads TypeScript to #1," https://github.blog/news-insights/octoverse/octoverse-a-new-developer-joins-github-every-second-as-ai-leads-typescript-to-1/, 2025, GitHub Blog, published 2025; accessed 2026-05-01.

[2] DORA, "State of AI-assisted Software Development 2025," https://dora.dev/research/2025/dora-report/, 2025, DORA research page, accessed 2026-05-01.

[3] Veracode, "2025 GenAI Code Security Report," https://www.veracode.com/wp-content/uploads/2025_GenAI_Code_Security_Report_Final.pdf, 2025, official report PDF, accessed 2026-05-01.

[4] GitGuardian, "The state of secrets sprawl report 2026," https://www.gitguardian.com/state-of-secrets-sprawl-report-2026, 2026, annual report page, accessed 2026-05-01.

[5] ——, "The State of Secrets Sprawl 2026: AI-Service Leaks Surge 81% and 29M Secrets Hit Public GitHub," https://blog.gitguardian.com/the-state-of-secrets-sprawl-2026/, 2026, official companion blog summary, published 2026-03-17; accessed 2026-05-01.

[6] RFC Editor, "Best current practice 14," https://www.rfc-editor.org/info/bcp14, 2026, rFC 2119 and RFC 8174 key words for requirements; accessed 2026-05-04.

[7] Semantic Versioning contributors, "Semantic versioning 2.0.0," https://semver.org/, 2026, official specification; accessed 2026-05-04.

[8] SPDX Project, "SPDX Specifications," https://spdx.dev/use/specifications/, 2026, official current and previous specification page; accessed 2026-05-04.

[9] OpenAPI Initiative, "OpenAPI Specification," https://spec.openapis.org/oas/, 2026, official specification site with schema guidance; accessed 2026-05-04.

[10] World Wide Web Consortium, "W3c process document," https://www.w3.org/policies/process/, 2026, official process document; accessed 2026-05-04.

[11] Cloud Native Computing Foundation, "Certified kubernetes conformance program," https://www.cncf.io/training/certification/software-conformance/, 2026, official CNCF software conformance page; accessed 2026-05-04.

[12] Open Source Security Foundation, "Openssf scorecard," https://openssf.org/scorecard/, 2026, official project page; accessed 2026-05-04.

[13] Stack Overflow, "AI: 2025 Developer Survey," https://survey.stackoverflow.co/2025/ai, 2025, official developer survey AI section; accessed 2026-05-01.

[14] OWASP Foundation, "OWASP Top 10 for Large Language Model Applications v2025," https://owasp.org/www-project-top-10-for-large-language-model-applications/assets/PDF/OWASP-Top-10-for-LLMs-v2025.pdf, 2025, official OWASP project PDF; accessed 2026-05-01.

[15] SetupBench Authors, "Setupbench: Assessing software engineering agents' ability to bootstrap development environments," *arXiv preprint arXiv:2507.09063*, 2025.

[16] ContextBench Authors, "Contextbench: A benchmark for context retrieval in coding agents," *arXiv preprint arXiv:2602.05892*, 2026.

[17] OpenAI, "Custom instructions with AGENTS.md," https://developers.openai.com/codex/guides/agents-md, 2026, codex documentation, accessed 2026-05-01.

[18] AGENTS.md contributors, "AGENTS.md," https://agents.md/, 2026, agent instruction file specification and guidance; accessed 2026-05-01.

[19] Anthropic, "How claude remembers your project," https://code.claude.com/docs/en/memory, 2026, claude Code documentation, accessed 2026-05-01.

[20] Cursor, "Cursor rules documentation," https://docs.cursor.com/en/context, 2026, cursor documentation, accessed 2026-05-01.

[21] GitHub, "Adding repository custom instructions for GitHub Copilot," https://docs.github.com/en/copilot/how-tos/copilot-on-github/customize-copilot/add-custom-instructions/add-repository-instructions, 2026, official documentation, accessed 2026-05-01.

[22] SWE-Effi Authors, "SWE-Effi: Re-Evaluating Software AI Agent System Effectiveness Under Resource Constraints," *arXiv preprint arXiv:2509.09853*, 2025.

[23] J. Yang, C. E. Jimenez, A. Wettig, K. Lieret, S. Yao, K. Narasimhan, and O. Press, "Swe-agent: Agent-computer interfaces enable automated software engineering," *arXiv preprint arXiv:2405.15793*, 2024.

[24] C. E. Jimenez, J. Yang, A. Wettig, S. Yao, K. Pei, O. Press, and K. Narasimhan, "SWE-bench: Can Language Models Resolve Real-World GitHub Issues?" in *International Conference on Learning Representations*, 2024.

[25] OpenHands Authors, "OpenHands: An Open Platform for AI Software Developers as Generalist Agents," *arXiv preprint arXiv:2407.16741*, 2024.

[26] Aider Contributors, "Aider: AI pair programming in your terminal," https://github.com/Aider-AI/aider, 2026, GitHub repository, accessed 2026-05-01.

[27] Microsoft Playwright, "Playwright best practices," https://playwright.dev/docs/best-practices, 2026, playwright documentation, accessed 2026-05-01.

[28] ——, "Writing tests," https://playwright.dev/docs/writing-tests, 2026, official documentation; accessed 2026-05-01.

[29] World Wide Web Consortium, "Understanding success criterion 2.5.8: Target size (minimum)," https://www.w3.org/WAI/WCAG22/Understanding/target-size-minimum.html, 2026, w3C Web Accessibility Initiative documentation; accessed 2026-05-01.

[30] web.dev, "Optimize cumulative layout shift," https://web.dev/articles/optimize-cls, 2025, last updated 2025-02-07; accessed 2026-05-01.

[31] Storybook, "Visual tests," https://storybook.js.org/docs/9/writing-tests/visual-testing, 2026, official documentation; accessed 2026-05-01.

[32] Microsoft Playwright, "Visual comparisons," https://playwright.dev/docs/test-snapshots, 2026, official documentation; accessed 2026-05-01.

[33] ——, "Snapshot testing: Aria snapshots," https://playwright.dev/docs/aria-snapshots, 2026, official documentation; accessed 2026-05-01.

[34] Argos CI, "Argos visual testing," https://argos-ci.com/visual-testing, 2026, product documentation; accessed 2026-05-01.

[35] BackstopJS contributors, "BackstopJS," https://github.com/garris/BackstopJS, 2026, open-source repository; accessed 2026-05-01.

[36] Microsoft Playwright, "Accessibility testing," https://playwright.dev/docs/accessibility-testing, 2026, official documentation; accessed 2026-05-01.

[37] Storybook, "Accessibility tests," https://storybook.js.org/docs/writing-tests/accessibility-testing, 2026, official documentation; accessed 2026-05-01.

[38] National Security Agency (NSA) and Cybersecurity and Infrastructure Security Agency (CISA), "Memory safe languages: Reducing vulnerabilities in modern software development," https://www.cisa.gov/resources-tools/resources/memory-safe-languages-reducing-vulnerabilities-modern-software-development, 2025, nSA/CISA cybersecurity information sheet, June 2025; accessed 2026-05-01.

[39] GitHub, "Working with secret scanning and push protection," https://docs.github.com/en/code-security/secret-scanning/working-with-secret-scanning-and-push-protection, 2026, official documentation; accessed 2026-05-01.

[40] Google OSV, "OSV-Scanner," https://google.github.io/osv-scanner/, 2026, official documentation; accessed 2026-05-01.

[41] SLSA Framework contributors, "Supply-chain Levels for Software Artifacts," https://slsa.dev/, 2026, official specification site; accessed 2026-05-01.

[42] M. Nottingham, E. Wilde, and S. Dalal, "Problem details for http apis," https://www.rfc-editor.org/rfc/rfc9457, 2023, rFC 9457.

[43] OpenTelemetry Authors, "OpenTelemetry Semantic Conventions," https://opentelemetry.io/docs/specs/otel/semantic-conventions/, 2026, official documentation, accessed 2026-05-01.

[44] ——, "Exception attributes," https://opentelemetry.io/docs/specs/semconv/registry/attributes/exception/, 2026, official semantic conventions; accessed 2026-05-01.

[45] MDN Web Docs contributors, "Error: cause," https://developer.mozilla.org/en-US/docs/Web/JavaScript/Reference/Global_Objects/Error/cause, 2026, mDN Web Docs; accessed 2026-05-01.

[46] Rust Project, "Error handling," https://doc.rust-lang.org/stable/rust-by-example/error.html, 2026, rust By Example; accessed 2026-05-01.

[47] anyhow contributors, "anyhow," https://docs.rs/anyhow/latest/anyhow/, 2026, rust crate documentation; accessed 2026-05-01.

[48] Microsoft, "Announcing TypeScript 7.0 Beta," https://devblogs.microsoft.com/typescript/announcing-typescript-7-0-beta/, 2026, TypeScript Dev Blog, published 2026-04-21; accessed 2026-05-01.

[49] Python Software Foundation, "Python Release Python 3.14.0," https://www.python.org/downloads/release/python-3140/, 2025, release date Oct. 7, 2025; accessed 2026-05-01.

[50] J. Bezanson, A. Edelman, S. Karpinski, and V. B. Shah, "Julia: A fresh approach to numerical computing," *SIAM Review*, vol. 59, no. 1, pp. 65–98, 2017.

[51] The Go Programming Language, “Results from the 2025 go developer survey,” https://go.dev/blog/survey2025, 2026, survey conducted Sept. 9-30, 2025; results published 2026; accessed 2026-05-01.
[52] OpenAPI Generator contributors, “OpenAPI Generator usage,” https://openapi-generator.tech/docs/usage, 2026, official documentation; accessed 2026-05-01.
[53] Buf, “Buf documentation,” https://buf.build/docs/, 2026, official documentation; accessed 2026-05-01.
[54] OpenTelemetry Authors, “OpenTelemetry Documentation,” https://opentelemetry.io/docs/, 2025, official documentation landing page, last modified 2025-08-29; accessed 2026-05-01.
[55] PostgreSQL Global Development Group, “Constraints,” https://www.postgresql.org/docs/current/ddl-constraints.html, 2026, postgreSQL documentation; accessed 2026-05-01.
[56] ——, “Row security policies,” https://www.postgresql.org/docs/current/ddl-rowsecurity.html, 2026, postgreSQL documentation; accessed 2026-05-01.
[57] Vite Team, “Vite 8.0 is out!” https://vite.dev/blog/announcing-vite8, 2026, vite blog, published 2026-03-12; accessed 2026-05-01.
[58] Protocol Buffers contributors, “Protocol Buffers Documentation,” https://protobuf.dev/overview/, 2026, official documentation; accessed 2026-05-04.
[59] JSON Schema contributors, “JSON Schema Specification,” https://json-schema.org/specification, 2026, official specification page for current and previous drafts; accessed 2026-05-04.
[60] OASIS, “Static Analysis Results Interchange Format (SARIF) Version 2.1.0,” https://docs.oasis-open.org/sarif/sarif/v2.1.0/sarif-v2.1.0.html, 2023, OASIS Standard; accessed 2026-05-04.